

Криптографические хэш-функции и целостность данных

1. Коллизии

Коллизия для хэш-функции H — это пара различных сообщений $m_0 \neq m_1$, для которых выполняется $H(m_0) = H(m_1)$. Поскольку пространство входных данных бесконечно (или очень велико), а выходное пространство фиксировано (n бит), по принципу Дирихле коллизии существуют всегда.

Криптографическая устойчивость к коллизиям

Хэш-функция считается криптографически устойчивой к коллизиям, если ни один эффективный (полиномиальный по времени) алгоритм A не может найти пару m_0, m_1 с заметной вероятностью:

$$\text{AdvCR}[A, H] = \Pr[A \text{ выводит коллизию для } H]$$

- AdvCR (Advantage of Collision Resistance) — насколько «силён» или «удачлив» конкретный хакер (противник) в попытке взломать хэш-функцию.
- $\Pr$ (Probability) — вероятность события.

Виды устойчивости

Тип	Название	Описание
1-й род	Устойчивость к прообразу	Для заданного M вычислительно неосуществимо найти M' , такое что $H(M) = H(M')$
2-й род	Устойчивость к коллизиям	Вычислительно неосуществимо найти любую пару (M, M') с одинаковым хэшем

Примечание: Не доказано существование необратимых хэш-функций, для которых нахождение прообраза теоретически невозможно. Как правило, это лишь вычислительно сложная задача — предполагается, что у злоумышленников недостаточно вычислительных мощностей.

2. Целостность

Целостность — это гарантия того, что сообщение не было изменено при передаче или хранении, без требования конфиденциальности (сообщение может быть открытым).

Примеры применения

- Защита публичных файлов на диске (предотвращение подмены системных файлов вирусом).

- Проверка баннеров на веб-страницах (предотвращение подмены рекламы злоумышленником).
- Верификация обновлений ПО (защита от подмены загружаемых файлов).

MAC (Message Authentication Code)

MAC — это пара алгоритмов $I = (S, V)$, определённых на множествах (K, M, T) .

Компоненты

Алгоритм	Роль	Описание
S (Sign/Generate)	Генерация метки	Принимает ключ K и сообщение M , возвращает тег $T = S(K, M)$
V (Verify, Требование согласованности)	Проверка метки	Принимает K, M, T ; возвращает yes (сообщение не изменено, тег t соответствует сообщению m при ключе k) или no

- K — пространство ключей (секретные значения).
- M — пространство сообщений (любые данные).
- T — пространство тегов (короткие «подписи с секретным ключом»).

Безопасность MAC

MAC $I = (S, V)$ считается безопасным, если для любого «эффективного» (полиномиального по времени) противника A :

$$\text{AdvMAC}[A, I] = \Pr[b = 1] < \text{"пренебрежимо мало"}$$

- $\text{AdvMAC}[A, I]$ — преимущество противника (вероятность успеха).
- $\Pr[b = 1]$ — вероятность того, что противник выиграл в «игре безопасности».

Построение MAC на основе PRF

PRF (Pseudorandom Function) — псевдослучайная функция $F: K \times X \rightarrow Y$, которая при случайном ключе k выглядит как случайная функция для любого наблюдателя, не знающего k . Оценка безопасности:

$$\text{AdvMAC}[A, I_F] \leq \text{AdvPRF}[B, F] + 1/|Y|$$

У противника есть лишь два пути к успеху:

- Найти изъян в функции F — доказать, что она предсказуема. Если F — это AES или SHA, этот шанс близок к нулю.
- Угадать тег — при $|Y| = 2^{80}$ вероятность угадать составляет 2^{-80} , что практически невозможно.

HMAC (Hash-based MAC)

HMAC — алгоритм создания цифровой метки для сообщения, объединяющий криптографическую хэш-функцию (например, SHA-256) и секретный ключ.

Входные данные

- Сообщение m
- Секретный ключ K
- Хэш-функция H (например, SHA-256)

Алгоритм вычисления

Шаг 1. Подготовка ключа:

- Если K длиннее блока хэш-функции $\rightarrow$ хэшируем: $K \leftarrow H(K)$
- Если K короче $\rightarrow$ дополняем нулями до длины блока

Шаг 2. Формирование ключей:

- Внутренний ключ: $K \oplus \text{ipad}$ (XOR с константой $0x36$)
- Внешний ключ: $K \oplus \text{opad}$ (XOR с константой $0x5C$)

Шаг 3. Вычисление:

- Внутренний хэш: берётся «Ключ №1», к нему приклеивается сообщение и хэшируется: $H((K \oplus \text{ipad}) || m)$
- Внешний хэш (итог): берётся «Ключ №2», к нему приклеивается результат из предыдущего шага и хэшируется ещё раз: $H((K \oplus \text{opad}) || \text{внутренний_хэш})$

Итоговая формула

$$\text{HMAC}(K, m) = H((K \oplus \text{opad}) || H((K \oplus \text{ipad}) || m))$$

Примечание: Безопасность HMAC зависит от качества базовой хэш-функции. Не следует использовать HMAC с устаревшими алгоритмами (MD5, SHA-1).

СВС-МАС (МАС на основе блочного шифра)

Проблема

Блочный шифр (например, AES) работает с фиксированным блоком (128 бит), тогда как сообщение m может быть произвольной длины: $m = m[0] || m[1] || \dots || m[n-1]$.

Решение

Использовать режим сцепления блоков (CBC) с финальным шифрованием на отдельном ключе.

Алгоритм

Входные данные:

- Сообщение, разбитое на блоки $[m[0], m[1], \dots, m[n-1]]$
- Два ключа (k, k_1) из пространства ключей блочного шифра

Шаги:

- Инициализация: зашифровать первый блок $m[0]$ функцией $F(k, \cdot)$
- Итерация (блоки от 1 до $n-2$): XOR с блоком сообщения $\rightarrow$ шифрование $F(k, \cdot) \rightarrow$ результат в следующий шаг

- Финальный блок $m[n-1]$: XOR с предыдущим результатом $\rightarrow$ шифрование $F(k_1, \cdot)$ — другой ключ
- Результат последнего шифрования — итоговый тег

Примечание: Использование двух ключей (k и k_1) защищает от атаки расширения сообщения: финальное шифрование на отдельном ключе исключает возможность предсказать внутреннее состояние и подделать тег.

3. Атака «дней рождения»

Суть атаки

Атака «дней рождения» позволяет находить коллизии для хэш-функции с длиной значений n бит в среднем за $2^{n/2}$ вычислений хэш-функции. Из этого следует: n -битная хэш-функция считается криптостойкой, если вычислительная сложность нахождения коллизий близка к $2^{n/2}$.

Алгоритм атаки

- Сгенерировать $\approx 2^{n/2}$ случайных сообщений $m_1, \dots, m_k$
- Вычислить их хэши: $t_i = H(m_i)$
- Отсортировать и проверить наличие совпадений: $t_i = t_j$ при $i \neq j$
- Если коллизия не найдена — повторить с новыми сообщениями